

CCSP D4 應用安全

CCSP flashcards for Knowt. 22 cards. Upload this PDF to AI PDF Summarizer.

Q001 發現未授權 API 時，為什麼不該立刻封鎖？

A 可能中斷合法業務。ISC2 常要先 gather more data，釐清業務需求與影響。

Q002 雲端開發者最容易失去哪項控制權？

A 底層 logging，因為日誌設施通常由 CSP 掌握。不是欄位驗證。

Q003 開發人員測試自己程式的核心問題是什麼？

A Conflict of interest / vested interest：他們希望軟體表現良好，因而產生盲點。

Q004 Forklifting 是什麼？

A 傳統應用不經修改直接搬上雲端，即 lift and shift。

Q005 REST 與 SOAP 怎麼分？

A SOAP 依賴嚴格 XML 協定標準；REST 核心優勢是輕量與可擴展。不要說 REST 建立在同樣嚴格的協定標準上。

Q006 IAM 的終極目的是什麼？

A Accountability（可歸責）。Authorization 只是過程。

Q007 ISO 27034 的 ONF 與 ANF 數量關係？

A 組織只有 1 個 ONF；每個應用有 1 個專屬 ANF。

Q008 要找程式設計邏輯錯誤，弱點掃描夠嗎？

A 不夠。弱掃描找已知系統弱點；邏輯錯誤靠原始碼審查 / SAST。

Q009 SAST 與 DAST 差在哪？

A SAST 看原始碼（白箱、開發期）；DAST 測運行中應用（黑箱、執行期）。

Q010 IAST 與 RASP 差在哪？

A IAST 在測試 / 執行中儀測以找漏洞；RASP 在執行期於應用內防禦攻擊。

Q011 API Gateway 與傳統防火牆差在哪？

A API Gateway 理解 API 呼叫、驗證、限流與應用層政策；傳統防火牆主要在網路層過濾。

Q012 Secure SDLC 的 shift left 是什麼意思？

A 把安全活動前移到需求、設計與開發，而不是只在上線前掃描。

Q013 Threat modeling 主要回答什麼？

A 系統有哪些資產、威脅、攻擊路徑與應優先的對策。

Q014 PaaS 測試的典型限制是什麼？

A 客戶可能無法對底層平台做完整基礎設施測試，只能在被允許的應用層範圍測試。

Q015 Code signing 的目的？

A 證明軟體來源與完整性，讓執行前能驗證發行者與未被篡改。

Q016 Nonfunctional requirements 常見包含什麼？

A 效能、可用性、可擴充性、安全性、可維護性等，不是功能清單本身。

Q017 Federated identity 解決什麼？

A 讓使用者用可信身分提供者的身分，跨組織 / 雲服務存取，而不在每個 SP 各建一套帳號。

Q018 OWASP Top 10 在 CCSP 怎麼用？

A 作為 Web / 應用常見風險清單與溝通框架，不是唯一合規標準。

Q019 Side-channel attack 在雲端為何被討論？

A 共享硬體可能讓攻擊者從時序、快取、電源等旁路推斷資訊。

Q020 應用安全題看到 best / first 時先問什麼？

A 這是治理 / 調查優先，還是立刻做技術強制。ISC2 常先選釐清與最小業務衝擊。

Q021 為什麼「工程師不擅長測試」通常是錯的？

A 那是情緒性說法。考試要的是獨立測試與利益衝突，不是能力貶低。

Q022 Release acceptance 的主要目的是什麼？

A 確認發行物符合既定驗收準則後才放行。文件化與核准是支撐，不是最上位目的。